

Clase 254 — OSINT técnico: Shodan y Censys

Parte: **12 — OSINT e ingeniería social** · Fuente: Documentación de Shodan y Censys · *Open Source Intelligence Techniques* (M. Bazzell) 🕒 Duración estimada: **100 min** · Nivel: **Intermedio**

🎯 Objetivo

Usar buscadores de dispositivos y servicios (Shodan y Censys) para inventariar la exposición técnica de una infraestructura en Internet, con dorks precisos y filtros. El alumno terminará capaz de localizar activos expuestos de su propia organización (o autorizada), evaluar su riesgo y priorizar remediación, entendiendo que estas plataformas indexan lo que ya está público.

⚖️ Nota ética

Consulta Shodan/Censys sobre **tus rangos IP, activos autorizados o servicios de laboratorio**. La consulta es pasiva (los datos ya están indexados), pero **no explotes ni te conectes** a sistemas de terceros que descubras. Reporta hallazgos ajenos por canal responsable.

📊 Resultados de aprendizaje

Al finalizar, el alumno podrá:

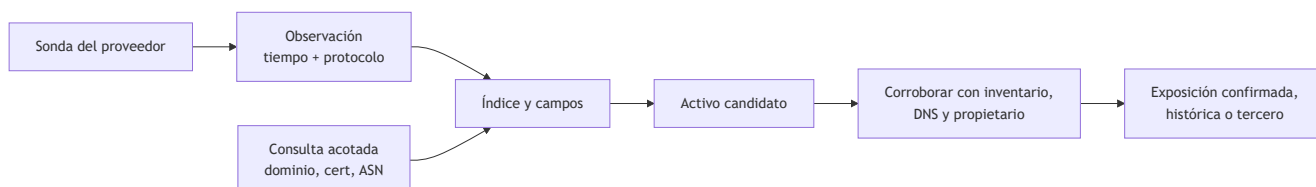
- 1. **Construir** consultas con filtros de Shodan (`port` , `org` , `net` , `product` , `ssl`).
- 2. **Usar** Censys para búsquedas por certificados, servicios y ASN.
- 3. **Identificar** servicios expuestos peligrosos (RDP, bases de datos, cámaras, ICS).
- 4. **Correlacionar** certificados y banners para atribuir activos a una organización.
- 5. **Priorizar** la remediación según severidad y exposición.

📖 Temas

#	Tema	Por qué importa
1	Qué indexan Shodan/Censys	Banners, puertos, certificados
2	Filtros y dorks de Shodan	Precisión en la búsqueda
3	Censys y búsqueda por certificados	Atribución por TLS
4	Servicios de alto riesgo	RDP, DB, ICS/SCADA, cámaras
5	CLI y API	Automatizar y exportar
6	Atribución de activos	Vincular IP a la organización
7	Priorización y reporte	Convertir exposición en acción

Un buscador de Internet ofrece observaciones, no un inventario perfecto

Shodan y Censys realizan mediciones y exponen resultados indexados de servicios accesibles. Cada registro depende de cuándo, desde dónde y con qué protocolo se observó. Puede estar desactualizado, corresponder a un proxy o CDN, o mostrar un banner configurado manualmente. Por ello una coincidencia es una **pista de exposición**, no confirmación de versión vulnerable ni autorización para conectarse activamente.



La consulta comienza con identificadores autorizados: dominios propios, certificados, rangos o etiquetas cloud. Buscar por banner genérico produce muchos falsos positivos. Los certificados pueden unir servicios, pero también ser compartidos; un ASN agrupa anuncios de red, no todos los activos de una organización; y una IP cloud puede reasignarse.

Observación pasiva y validación activa

Consultar el índice evita enviar tráfico directo al activo, aunque el proveedor obtuvo los datos mediante mediciones. Validar activamente con `nmap`, navegador o un cliente ya cambia la interacción y requiere alcance y permiso. Esta clase limita la práctica a activos propios o laboratorios y conserva consultas, fecha de observación y filtros. No se explotan resultados encontrados en Internet.

Para reducción de superficie se compara el inventario esperado con el observado: puertos, protocolos, certificados y regiones. La diferencia puede revelar un activo desconocido, una entrada antigua o un servicio de un tercero. Antes de abrir un incidente se asigna propietario y se verifica vigencia mediante fuentes internas.

Banners, vulnerabilidades y priorización

Un banner de versión no demuestra que el software sea vulnerable: puede ocultar parches retroportados o ser falso. La asociación con CVE se presenta como candidata hasta verificar producto, versión, configuración y alcance. Exposiciones administrativas, bases de datos o protocolos sin cifrar se priorizan por datos y control accesibles, no solo por el número de puerto.

Caso razonado: base de datos «de la empresa»

Una búsqueda por dominio de certificado encuentra una IP con MongoDB. RDAP muestra un proveedor cloud y DNS ya no apunta allí; el certificado fue observado meses antes. El analista consulta inventario y confirma que era una prueba eliminada. Clasifica el registro como histórico y solicita revisar retención del certificado, en vez de afirmar que existe una base abierta actual.

Glosario operativo

Término	Definición útil
Banner	Respuesta o metadato de servicio; puede ser incompleto o engañoso.
Índice de medición	Base construida con observaciones realizadas en momentos concretos.
Exposición	Servicio accesible desde una posición de red determinada.
Activo candidato	Resultado pendiente de validar propiedad, vigencia y función.
Validación activa	Interacción directa con el servicio, sujeta a autorización.

Criterio de dominio

Existe dominio cuando el alumno crea consultas acotadas sobre infraestructura autorizada, registra tiempo y procedencia, valida propiedad y vigencia, separa banner de vulnerabilidad y produce una acción defensiva sin ampliar el alcance.

Definiciones y características

- **Banner:** respuesta que un servicio muestra al conectar (versión, cabeceras). Característica: base del fingerprinting remoto.
- **Dork:** consulta con filtros específicos. Característica: separa ruido de activos relevantes.
- **ASN:** número de sistema autónomo que agrupa rangos IP de una entidad. Característica: útil para delimitar la superficie.
- **Certificate pivoting:** encontrar activos por el mismo certificado/organización TLS. Característica: revela infraestructura oculta.
- **ICS/SCADA:** sistemas de control industrial expuestos. Característica: hallazgos críticos por su impacto físico.
- **Facet:** agregación estadística de resultados (por país, puerto, producto). Característica: da visión macro de la exposición.

Herramientas y preparación

- **Cuentas:** Shodan (<https://www.shodan.io>) y Censys (<https://search.censys.io>), plan gratuito basta para practicar.
- **CLI:** `pip install shodan` y `shodan init <API_KEY>`; API de Censys con `censys` CLI.
- **Complementos:** navegador con la extensión Shodan; `nmap` para validar (solo sobre activos propios/autorizados).
- **Recordatorio:** consultar es pasivo; conectarse o explotar activos ajenos no lo es y no está permitido.

Laboratorio guiado

Objetivo: **tu IP pública / activos autorizados** y ejemplos de laboratorio.

1. Averigua tu IP pública y consúltala: `shodan host <tu_ip>` — revisa puertos y banners expuestos.
2. Búsqueda por organización (autorizada): en la web de Shodan, `org:"Tu Organizacion"`.

3. Filtros combinados: `port:3389 org:"Tu Organizacion"` para RDP expuesto; `product:MongoDB` para bases sin auth.
4. Facets: en Shodan, usa la vista de estadísticas para ver distribución por puerto/país de tu rango.
5. Censys: busca por certificado `services.tls.certificates.leaf_data.subject.organization: "Tu Org"`.
6. Atribuye activos: correlaciona certificados y banners para confirmar que son tuyos.
7. Exporta: `shodan search --fields ip_str,port,org "net:<tu_rango>" > exposicion.csv`.
8. Prioriza: marca RDP, DB abiertas y paneles admin como críticos; redacta plan de cierre.

Ejercicios

1. Escribe 5 dorks de Shodan para servicios de alto riesgo y explica cada filtro.
2. Compara resultados de Shodan y Censys sobre el mismo activo autorizado.
3. Usa `certificate pivoting` en Censys para descubrir activos relacionados.
4. Interpreta un banner y deduce versión y posible CVE asociado.
5. Genera un CSV de exposición y clasifícalo por severidad.
6. Explica por qué encontrar un sistema ICS ajeno obliga a reporte responsable, no a interacción.

Reto verificable

Entrega un **inventario de exposición en Internet** de un rango autorizado con: activos, puertos, servicios de riesgo, atribución por certificado y plan de remediación priorizado. **Criterio de aceptación:** cada activo se obtuvo solo por consulta (sin conexión directa), la atribución está justificada y los ítems críticos tienen acción y responsable propuestos.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
"No information available"	IP no indexada o sin servicios. Verifica el rango o espera reindexado.
Demasiados resultados irrelevantes	Dork poco específico. Añade <code>org</code> , <code>net</code> o <code>product</code> .
Datos desactualizados	El banner es de un escaneo antiguo. Confirma con validación autorizada.
Atribución errónea	IP compartida/hosting. Corroborar con certificado y DNS.
Tentación de conectarse a un hallazgo	Fuera de alcance. Consultar sí, interactuar no; reporta si es de terceros.

Preguntas frecuentes

 **¿Es legal usar Shodan?** Sí: indexa información pública. Lo ilegal es interactuar con o explotar sistemas de terceros que descubras sin autorización.

 **¿Shodan o Censys?** Se complementan. Shodan destaca en IoT/ICS y facilidad; Censys en búsqueda por certificados y datos estructurados. Usa ambos.

? ¿Los datos son en tiempo real? No. Son escaneos periódicos; un banner puede estar desactualizado. Valida antes de concluir en un engagement.

Referencias

- Shodan — Docs. <https://help.shodan.io/>
- Censys — Search. <https://search.censys.io/>
- Shodan CLI. <https://cli.shodan.io/>
- Bazzell, M. *Open Source Intelligence Techniques*. <https://inteltechniques.com/book1.html>
- MITRE ATT&CK — Active Scanning (T1595). <https://attack.mitre.org/techniques/T1595/>

Material descargable

-  [Guía en PDF](#) — versión imprimible de esta clase.
-  [Presentación \(PPTX\)](#) — deck para proyectar en clase.

Clase anterior

[Clase 253 — Geolocalización y análisis de imágenes](#)

Siguiente clase

[Clase 255 — Automatización de OSINT: SpiderFoot y Maltego](#)